```yaml
apiVersion: armor.io/v2
kind: Policy                          # ONE kind (D4 direction settled by D11: baselines, not kinds)
metadata:
  name: string                        # unique per (org, target); upsert key
  description: string?                # optional
  orgId: uuid                         # REQUIRED enterprise/team; ABSENT solo-local
  labels: {team: payments}?           # free-form, display and filtering only
target:                               # exactly one form
  agent: uuid-or-slug                 # enterprise agent (always binds its MCPs)
  mcpServers: [github, filesystem]    #   servers this policy also governs
  # group: payments                   # every agent whose policyGroup is "payments" (D10)
  # org: "*"                          # enterprise org floor
  # device: local                     # local policy, one per user (replaces product:)
spec:
  tools:
    default: allow | hold | block     # REQUIRED, the no-match verdict
    rules:                            # map: key to verdict, or to an ordered variant list
      Read: allow                     # scalar shorthand (the 90% case)
      "mcp__github__*": allow         # glob key; exact beats glob, longer glob beats shorter
      destructive: hold               # CAPABILITY key: binds by tag on fleet agents (§7.8)
      file.write:                     # capability key with variants
        - when: {path: {glob: "**/*.tf"}}
          action: hold
          controls: [SOC2-CC8.1]
        - action: allow
      Bash:                           # ordered variants; first match wins
        - when: {command: {matches: '(^|\s)rm\s+-[a-zA-Z]*[rf][a-zA-Z]*[rf]'}}
          action: block
          reason: recursive force delete
          controls: [SOC2-CC6.1]
        - when: {program: {in: [ls, grep, cat, git]}, writeRedirection: {eq: false}}
          action: allow
        - action: hold                # everything else Bash does
      create_payment:
        - when: {args.amount: {gt: 5000}}
          action: hold
          approval: {approvers: 2, roles: [finance_lead]}
          controls: [SOC2-CC6.1, SOC2-CC7.2]
        - action: allow
  files:                              # capability floor, any event carrying a path
    deny: ["~/.ssh/**", "**/.env*", "**/*.pem"]
    allowOutsideWorkspace: false
  network:                            # destination floor, any event carrying a host or URL
    default: deny
    allow: ["*.github.com", {host: api.stripe.com, reason: payments}]
    deny: [{host: 169.254.169.254, reason: AWS IMDS credentials endpoint}]
  skills:
    default: allow
    hold: ["*:deploy*"]               # ':' namespaced globs
  secrets:                            # local surfaces only
    envBlocklist: [AWS_SECRET_ACCESS_KEY, GITHUB_TOKEN]
  members:                            # enterprise/team only; OVERRIDES the base, floor-bounded (D1=d)
    "alice@armoriq.io":
      tools:
        rules:
          create_payment:             # loosening: alice gets what the base blocks
```

```
          - action: allow
            expiresAt: 2026-12-31T00:00:00Z   # per-RULE expiry, optional
    expiresAt: never              # per-SCOPE expiry; optional in YAML, always materialized
  "bob@armoriq.io":
    tools: {rules: {search_transactions: block}}   # tightening
  "team:interns":
    tools: {default: block}
capture:
  arguments: true
  redact: ["*token*", "*secret*", "authorization"]
  maxBytesPerCall: 16384
  sample: 1.0                     # hold/block always 1.0
approvalDefaults: {approvers: 1, roles: [admin]}
```

Local-only section. A document with `target: {device: local}` may additionally carry a `products:` overlay, one block per local agent with the same overlay mechanics as `members:`. It is illegal on any enterprise target and the compiler rejects it there. There is no `precedence` field (D17, 2026-09-13): the device file and its `products:` overlay have one owner, so the one layering principle of §7.5 applies and a product block may widen or tighten the base, with every widening flagged at compile time and printed by Armor CLI at apply time. A document carrying `precedence` fails strict parsing as an unknown key.